



UNIVERSITÀ DEGLI STUDI DI SALERNO

Dipartimento di Ingegneria dell'Informazione ed Elettrica e Matematica
Applicata.

Corso di Algoritmi e Protocolli di Sicurezza

Aequitas

Sistema di Voto Elettronico

Progettazione e analisi di un protocollo elettorale
a preferenza nominale.

Autori

Autorino Luigi – IE22700117

Chirico Emanuel – IE22700187

Elaborato

Project Work

A.A. 2025–2026

Giugno 2026

Capitolo 1

Work Package 1

1.1 Scenario e Architettura Logica

Il presente capitolo definisce l'architettura logica del progetto **Aequitas**, un sistema di voto elettronico ideato per consultazioni elettorali con preferenza nominale, quale lo scenario tipico delle elezioni comunali. Per soddisfare i requisiti di sicurezza e garantire il rispetto dei principi democratici fondamentali, l'infrastruttura è stata disegnata attorno a un paradigma di **isolamento funzionale** e **fisico**. Tale approccio impone una rigida separazione delle responsabilità di sicurezza e operative tra i diversi nodi della rete. Gli attori principali designati per questo sistema sono:

1. **Electoral Authority ($\mathcal{E}$)**: l'autorità centrale del sistema **Aequitas**, responsabile dell'indizione e del coordinamento dell'intera elezione. Nella fase di setup, ha il compito di predisporre il sistema e autorizzare ufficialmente l'avvio delle votazioni. Al termine delle operazioni di voto, $\mathcal{E}$ decreta la chiusura delle urne, raccoglie i risultati dello spoglio elaborati dai fiduciari (*Trustees*) per ricostruire l'esito finale e, infine, ne certifica la validità pubblicandolo formalmente sul registro pubblico del VBR.
2. **Trustees ($\mathcal{T}$)**: i fiduciari del sistema, indicati con l'insieme $\mathcal{T} = \{\mathcal{T}_1, \mathcal{T}_2, \dots, \mathcal{T}_n\}$, introdotti per decentralizzare la fiducia ed evitare che un singolo attore abbia il controllo assoluto sulle urne. Agiscono come custodi responsabili e verificabili, con il compito di tutelare la segretezza del voto custodendo, in modo distribuito, le singole porzioni dei segreti necessari allo spoglio. Il loro intervento attivo avviene esclusivamente a votazioni concluse: in questa fase, i Trustee procedono a rivelare la propria share impegnata. Tale azione consente che le successive fasi di ricostruzione del segreto e di decifratura siano operazioni interamente pubbliche, garantendo la totale trasparenza del processo e assicurando che nessuna singola entità abbia il potere di leggere il contenuto delle schede in autonomia o in anticipo.
3. **Voter (V) e Client Application**: l'Elettore (V) è l'utente legittimo avente diritto al voto, entità da cui ha origine la scelta elettorale. Dal punto di vista infrastrutturale, l'interazione umana con l'intera architettura è mediata da una *client application*, un software in esecuzione sul dispositivo personale dell'utente. Questa applicazione ha il duplice obiettivo di proteggere la segretezza della preferenza e di fornire all'elettore gli strumenti necessari per la verificabilità individuale, consentendogli di accertarsi autonomamente che il proprio voto sia stato correttamente acquisito dal sistema.
4. **Identity & Authentication Provider (IAP)**: autorità istituzionale preposta esclusivamente all'identificazione e all'accreditamento degli aventi diritto al voto. Il suo obiettivo primario è garantire l'integrità del bacino elettorale, accertandosi che solo gli utenti autorizzati possano partecipare. Dopo aver verificato l'identità e il diritto di voto, l'IAP rilascia all'elettore un'autorizzazione formale all'accesso alle

urne, operando in completa cecità rispetto al contenuto del voto per preservare lo pseudo-anonimato.

5. **Verified Ballot Register (VBR)**: è il componente che accentra le responsabilità di ricezione, validazione e persistenza dei voti. All'atto della ricezione, il VBR verifica autonomamente la validità delle autorizzazioni rilasciate dall'IAP e l'unicità del voto, rigettando pacchetti malformati o duplicati. Validazione e salvataggio avvengono come un'unica operazione sicura all'interno della sua struttura: progettato come un registro pubblico inalterabile di sola aggiunta, il VBR funge da fonte di verità del sistema e garantisce la verificabilità individuale e universale. Non possiede alcuna capacità di accedere al contenuto in chiaro dei voti.

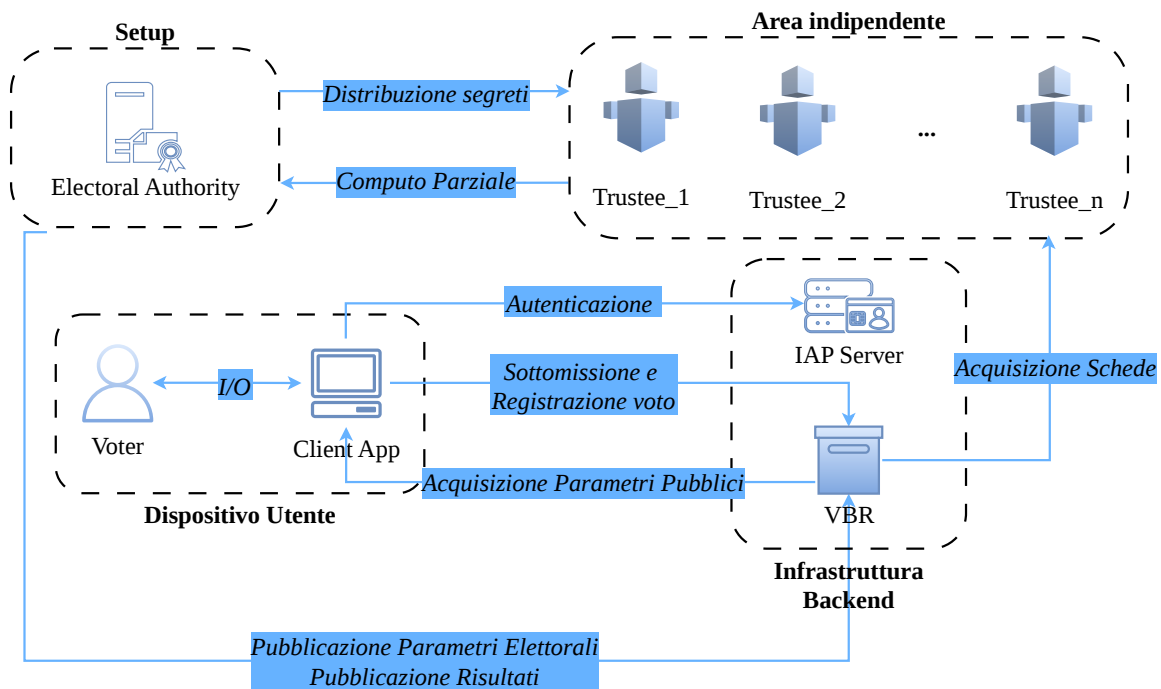


Figura 1.1: Diagramma dell'architettura 'Aequitas'.

1.2 Obiettivi e Proprietà di Sicurezza

Il sistema **Aequitas** è definito attraverso diverse **proprietà di sicurezza** critiche o ad alta priorità. Ciascuna proprietà stabilisce un vincolo sulla correttezza e la riservatezza del processo elettorale, dal momento dell'autenticazione fino allo scrutinio finale. La tabella seguente fornisce la definizione formale di ogni proprietà, il livello di priorità assegnatogli, e il riferimento ai vettori di attacco. Questa organizzazione rende esplicito il collegamento tra i requisiti di sicurezza astratti e le minacce concrete.

ID	Proprietà	Definizione	Minacce associate	Priorità
1	Integrità del diritto di voto	Solo gli aventi diritto registrati nel registro elettorale possono esprimere un voto valido. Il rispetto di questo requisito previene il doppio voto.	Double Voting	Media
2	Integrità della scelta di voto	La preferenza nominale espressa dal votante deve corrispondere esattamente al pacchetto crittografico trasmesso al VBR, senza alterazioni intermedie.	Man-in-the-middle	Alta
3	Segretezza del voto	Il contenuto della scheda di voto deve rimanere protetto end-to-end. Nessun attore, incluso l'IAP, può visualizzare la preferenza del votante.	Tentativo di correlare identità e voto, Collusione IAP-VBR	Alta
4	Pseudo-Anonimato	Non deve sussistere alcun legame matematico o temporale evidente tra l'identità autenticata presso l'IAP e il voto registrato nel VBR.	Coercizione	Alta
5	Verificabilità	Il sistema garantisce verificabilità individuale permettendo agli elettori di controllare che il proprio voto sia stato acquisito. Per la verificabilità universale , la correttezza dell'esito finale rispetto ai voti nel VBR è garantita tramite ricomputazione pubblica: chiunque può ricalcolare e validare lo spoglio in modo indipendente.	Individuale: omissione del voto Universale: computo fraudolento dei voti	Alta

1.3 Threat Modeling e Scenari di Attacco

In questo paragrafo si è scelto di elencare i vari threat models e gli attacchi in base alla proprietà che si cerca di preservare.

1.3.1 Modello degli avversari

Per definire gli avversari in maniera coerente con il modello teorico della crittografia moderna, si adotta il paradigma computazionale standard. In questo contesto, un avversario $\mathcal{A}$ viene modellato come un **PPT** (*Probabilistic Polynomial-Time*), ossia come un algoritmo probabilistico che termina in tempo polinomiale, capace di tentare l'alterazione dello schema con probabilità non nulla ed entro vincoli computazionalmente realistici.

Definita formalmente la struttura dei vari attaccanti dello schema, è importante formalizzare la **probabilità di successo** di un attaccante: ovviamente, per garantire che Aequitas sia sicuro, la probabilità che ciascun attaccante abbia successo deve essere matematicamente trascurabile. Una funzione $\text{negl}(\lambda)$ è definita **trascurabile** se per ogni polinomio positivo $p(\cdot)$, esiste un intero λ_0 tale che per ogni $\lambda > \lambda_0$, vale:

$$\text{negl}(\lambda) < \frac{1}{p(\lambda)} \quad (1.1)$$

Definito un gioco di sicurezza $\mathcal{G}$ parametrizzato rispetto a 1^λ , si definisce il vantaggio dell'avversario $\mathcal{A}$, denotato con $\text{Adv}_{\mathcal{A}}^{\mathcal{G}}(\lambda)$, in base alla natura dell'esperimento crittografico:

- **esperimenti di indistinguibilità:** per le proprietà modellate come giochi di indistinguibilità (es. la segretezza del voto), l'avversario deve tipicamente distinguere tra due distribuzioni. Un avversario che effettua una scelta puramente casuale ha una probabilità di successo pari a $\frac{1}{2}$. In questo scenario, il vantaggio è definito come la deviazione assoluta da tale probabilità attesa:

$$\text{Adv}_{\mathcal{A}}^{\mathcal{G}}(\lambda) = \left| \Pr[\mathcal{A} \text{ vince } \mathcal{G}(1^\lambda)] - \frac{1}{2} \right| \quad (1.2)$$

Il sistema si definisce sicuro rispetto a questa proprietà se il vantaggio dell'avversario è limitato superiormente da una funzione trascurabile, equivalente a richiedere che:

$$\Pr[\mathcal{A} \text{ vince } \mathcal{G}(1^\lambda)] \leq \frac{1}{2} + \text{negl}(\lambda) \quad (1.3)$$

- **Giochi di falsificazione:** Per le proprietà modellate come giochi di falsificazione o estrazione (es. unicità del voto, integrità), l'obiettivo dell'avversario è forgiare una prova valida o violare un costrutto deterministico. In questi casi, la probabilità di successo di un avversario casuale è nulla. Pertanto, il vantaggio coincide esattamente con la probabilità complessiva di vittoria dell'avversario:

$$\text{Adv}_{\mathcal{A}}^{\mathcal{G}}(\lambda) = \Pr[\mathcal{A} \text{ vince } \mathcal{G}(1^\lambda)] \quad (1.4)$$

Per questa classe di giochi, il sistema si considera sicuro se e solo se:

$$\Pr[\mathcal{A} \text{ vince } \mathcal{G}(1^\lambda)] \leq \text{negl}(\lambda) \quad (1.5)$$

1.3.2 Classificazione degli avversari

Per questo progetto, si è scelto di classificare tutti i possibili attaccanti lungo due assi ortogonali:

- **posizione nel sistema**, dove l'attaccante può essere interno (quindi legittimo ma malintenzionato) oppure esterno (nessun ruolo nel protocollo);
- **modello di corruzione**, dove l'attaccante può essere *honest-but-curious*, dunque segue il protocollo ma tenta di accedere ai dati, oppure *malicious*, ossia prova a deviare il protocollo in maniera arbitraria.

Si precisa che la modellazione degli avversari in questa sezione ha scopo analitico: ciascun attore interno viene analizzato nel caso peggiore, indipendentemente dalle assunzioni operative dichiarate nella sezione 1.4.1. L'obiettivo è identificare i rischi potenziali del sistema e comprendere quali proprietà reggono crittograficamente e quali dipendono invece dalle assunzioni di fiducia adottate. Per questo specifico sistema, sono state pensate cinque tipologie di attaccanti differenti, elencate di seguito:

- **$\mathcal{A}_V$ - Votante malizioso**

Il votante malizioso è un partecipante **legittimo** del sistema che tenta di violare la proprietà di **unicità** del voto. Formalmente, $\mathcal{A}_V$ è un avversario PPT interno di tipo *malicious*. Definito il gioco $\mathcal{G}_{\mathcal{A}_V}^{uniq}(1^\lambda)$ come l'esperimento di falsificazione dell'unicità, si definiscono le seguenti tre fasi:

1. $\mathcal{A}_V$ esegue una singola sessione di accreditamento, ottenendo una prova di autorizzazione σ .
2. $\mathcal{A}_V$ tenta di produrre e sottomettere due pacchetti di voto distinti e validi (v_1, σ_1) e (v_2, σ_2) .
3. $\mathcal{A}_V$ vince il gioco se entrambi i voti superano la fase di verifica da parte del VBR e vengono regolarmente conteggiati.

Passando alle capacità, $\mathcal{A}_V$ può aprire sessioni parallele con l'IAP, manipolare il proprio client, ritardare o ritrasmettere i messaggi (*Replay Attack*). Tuttavia, questo attaccante non può corrompere l'entità IAP, né alterare il comportamento del VBR relativamente ai controlli di unicità. Ovviamente, l'obiettivo finale di questo attaccante è inserire nel VBR più di una preferenza valida a fronte di una singola identità.

Essendo un esperimento basato sulla falsificazione di una prova di unicità, per garantire la sicurezza del sistema bisogna assicurare che il vantaggio dell'avversario coincida con la sua probabilità di vittoria e che questa sia trascurabile:

$$Adv_{\mathcal{A}_V}^{uniq}(\lambda) = Pr[\mathcal{A}_V \text{ vince } \mathcal{G}_{\mathcal{A}_V}^{uniq}(1^\lambda)] \leq \text{negl}(\lambda) \quad (1.6)$$

- $\mathcal{A}_{IAP}$ - IAP malizioso

L'IAP malizioso è un'entità interna che conosce l'identità di ogni votante e tenta di correlare questa informazione al contenuto del voto, oppure tenta di emettere autorizzazioni al voto in eccesso per alterare l'esito elettorale. Formalmente, $\mathcal{A}_{IAP}$ è un avversario PPT interno di tipo *malicious* che controlla completamente il componente IAP. Per questo attaccante si è deciso di modellare due giochi distinti:

- **Gioco $\mathcal{G}_{\mathcal{A}_{IAP}}^{link}(1^\lambda)$: violazione della segretezza di votazione (De-anonymization):**

1. $\mathcal{A}_{IAP}$ osserva tutte le richieste di accreditamento e i valori ricevuti in chiaro dai client.
2. Lo sfidante seleziona casualmente un votante $V \in \mathcal{V}^*$.¹
3. $\mathcal{A}_{IAP}$ vince il gioco se riesce a determinare, per il votante V , quale pacchetto nel registro pubblico gli appartiene, stabilendo così un collegamento tra identità e preferenza.

In questo gioco, si fa la rigorosa assunzione di fiducia di non-collusione nei confronti del VBR: l'IAP non ha accesso ai log di rete del VBR né alle tempistiche di sottomissione.

- **Gioco $\mathcal{G}_{\mathcal{A}_{IAP}}^{stuff}(1^\lambda)$ - Violazione della validità del voto (*Ballot Stuffing*):**

1. $\mathcal{A}_{IAP}$ genera ed emette arbitrariamente autorizzazioni al voto non associate ad alcun votante legittimo.
2. $\mathcal{A}_{IAP}$ vince il gioco se alla fine delle operazioni di voto risultano registrati e accettati dal VBR un numero k di voti validi tale che $k > |R|$, dove $|R|$ è la cardinalità del registro degli elettori aventi diritto.

L'attaccante $\mathcal{A}_{IAP}$ ha l'accesso completo al registro elettorale, alle identità dei votanti e alle sessioni di accreditamento. Non controlla tuttavia il VBR, per il quale si effettua l'assunzione di fiducia.

Affinché il sistema sia ritenuto sicuro contro questo avversario, i vantaggi in entrambi i giochi crittografici (formulati come probabilità di estrazione/falsificazione) devono essere trascurabili:

$$Adv_{\mathcal{A}_{IAP}}^{link}(\lambda) = Pr[\mathcal{A}_{IAP} \text{ vince } \mathcal{G}_{\mathcal{A}_{IAP}}^{link}(1^\lambda)] \leq negl(\lambda) \quad (1.7)$$

$$Adv_{\mathcal{A}_{IAP}}^{stuff}(\lambda) = Pr[\mathcal{A}_{IAP} \text{ vince } \mathcal{G}_{\mathcal{A}_{IAP}}^{stuff}(1^\lambda)] \leq negl(\lambda) \quad (1.8)$$

¹ $\mathcal{V}^*$ indica l'insieme degli elettori che hanno sottomesso con successo un voto valido all'interno del VBR.

- **$\mathcal{A}_{VBR}$ - VBR malizioso**

Il VBR malizioso è un'entità interna preposta alla ricezione e persistenza dei voti. Formalmente, $\mathcal{A}_{VBR}$ è un avversario PPT interno di tipo *malicious* che controlla completamente il VBR e tenta di alterare l'integrità dell'urna digitale.

Per questo attaccante si definisce il gioco $\mathcal{G}_{\mathcal{A}_{VBR}}^{ledger}(1^\lambda)$ e le relative tre fasi:

1. Il sistema (VBR) riceve un insieme di voti validi e regolarmente autorizzati $\mathcal{V} = \{(v_i, \sigma_i)\}_{i=1}^n$.
2. $\mathcal{A}_{VBR}$ tenta di persistere all'interno del registro pubblico un insieme di voti alterato $\mathcal{V}' \neq \mathcal{V}$ (ad esempio, omettendo schede legittime appena ricevute o inserendo schede contraffatte).
3. $\mathcal{A}_{VBR}$ vince il gioco se l'insieme alterato $\mathcal{V}'$ sfugge ai controlli di integrità. Nello specifico, vince se le omissioni non vengono denunciate dagli elettori (fallimento della verificabilità individuale) o se gli inserimenti illegittimi superano la validazione crittografica pubblica da parte degli osservatori esterni (fallimento della verificabilità universale).

L'attaccante $\mathcal{A}_{VBR}$ non ha alcuna visibilità in chiaro sul contenuto dei voti e non esegue operazioni di sblocco o di conteggio. Il suo obiettivo è puramente mirato a compromettere l'integrità e la disponibilità del suffragio. Essendo un gioco di falsificazione delle prove di integrità del registro, per garantire la sicurezza del sistema la probabilità di vittoria dell'avversario deve essere trascurabile:

$$Adv_{\mathcal{A}_{VBR}}^{ledger}(\lambda) = Pr[\mathcal{A}_{VBR} \text{ vince } \mathcal{G}_{\mathcal{A}_{VBR}}^{ledger}(1^\lambda)] \leq negl(\lambda) \quad (1.9)$$

- **$\mathcal{A}_{ext}$ - Attaccante esterno**

L'attaccante esterno non ha alcun ruolo attivo e legittimo nel protocollo, ma ha accesso al canale di comunicazione tra i componenti. Formalmente, $\mathcal{A}_{ext}$ è un avversario PPT esterno dotato di duplice capacità sul canale di comunicazione:

- **capacità passive:** osserva la comunicazione e raccoglie dati (eavesdropping) con l'obiettivo di violare la confidenzialità dei payload o effettuare analisi del traffico sul canale;
- **capacità attive:** manipola direttamente il canale di comunicazione iniettando dati arbitrari, bloccando pacchetti legittimi (Drop Attack) o ritrasmettendo comunicazioni passate (Replay Attack), al fine di compromettere l'integrità, l'autenticità o la disponibilità dell'infrastruttura.

Si definisce il gioco $\mathcal{G}_{\mathcal{A}_{ext}}^{mitm}(1^\lambda)$ e le seguenti tre fasi:

1. $\mathcal{A}_{ext}$ si interpone sul canale di comunicazione tra il votante e i nodi strutturali (IAP e VBR).
2. Sfruttando le capacità attive e passive precedentemente definite, $\mathcal{A}_{ext}$ tenta di violare la confidenzialità delle comunicazioni oppure l'integrità del flusso elettorale o anche analizzare il traffico di rete.
3. $\mathcal{A}_{ext}$ vince se almeno uno degli obiettivi elencati viene raggiunto con successo, aggirando i controlli crittografici o le mitigazioni applicative del client.

Il raggio d'azione di $\mathcal{A}_{ext}$ risiede esclusivamente nel controllo del canale di rete, non avendo accesso ai segreti crittografici degli attori legittimi, per le quali vige la

consueta **assunzione di fiducia** nella corretta custodia da parte degli *end-point*. La condizione di sicurezza è espressa come:

$$Adv_{\mathcal{A}_{ext}}^{mitm}(\lambda) = Pr[\mathcal{A}_{ext} \text{ vince } \mathcal{G}_{\mathcal{A}_{ext}}^{mitm}(1^\lambda)] \leq negl(\lambda) \quad (1.10)$$

- **$\mathcal{A}_{FID}$ - Fiduciario malizioso**

Il **Fiduciario malizioso** è un'entità interna che custodisce una porzione dei segreti necessari alla fase di scrutinio e può tentare di ricavare informazioni sui voti prima della chiusura delle urne, oppure di alterare il risultato finale trasmettendo deliberatamente valori scorretti durante le operazioni di sblocco.

Formalmente, $\mathcal{A}_{FID}$ è un avversario PPT interno che può essere modellato secondo due livelli di capacità offensiva.

- **Caso 1 : *Honest-but-curious*:**

il fiduciario segue correttamente il protocollo ma tenta di ricavare informazioni sui voti dai frammenti di segreto in suo possesso. Si definisce il gioco $\mathcal{G}_{\mathcal{A}_{FID}}^{secret}(1^\lambda)$:

- * $\mathcal{A}_{FID}$ possiede la propria porzione di segreto e osserva le porzioni di al più altri $t - 1$ fiduciari.
- * $\mathcal{A}_{FID}$ vince se riesce a ricavare il contenuto in chiaro di almeno un pacchetto presente nel registro del VBR.

Il sistema si considera sicuro rispetto a questo gioco se il vantaggio dell'avversario è trascurabile rispetto al parametro di sicurezza λ :

$$Adv_{\mathcal{A}_{FID}}^{secret}(\lambda) = Pr[\mathcal{A}_{FID} \text{ vince } \mathcal{G}_{\mathcal{A}_{FID}}^{secret}(1^\lambda)] \leq negl(\lambda) \quad (1.11)$$

- **Caso 2 : *Malicious*:**

il fiduciario devia arbitrariamente dal protocollo, trasmettendo una porzione di segreto deliberatamente scorretta durante la fase di sblocco delle urne. Si definisce il gioco $\mathcal{G}_{\mathcal{A}_{FID}}^{tally}(1^\lambda)$:

- * $\mathcal{A}_{FID}$ rivela una share falsa in sostituzione della propria reale porzione di segreto custodita.
- * $\mathcal{A}_{FID}$ vince se il risultato finale pubblicato differisce dal risultato corretto e la manipolazione non viene rilevata dal controllo di consistenza pubblica.

Il sistema si considera sicuro rispetto a questo gioco se il vantaggio dell'avversario è trascurabile:

$$Adv_{\mathcal{A}_{FID}}^{tally}(\lambda) = Pr[\mathcal{A}_{FID} \text{ vince } \mathcal{G}_{\mathcal{A}_{FID}}^{tally}(1^\lambda)] \leq negl(\lambda) \quad (1.12)$$

L'attaccante $\mathcal{A}_{FID}$ non controlla il VBR in fase di lettura pubblica, per i quali vige l'assunzione di fiducia operativa. Non ha accesso alle porzioni di segreto degli altri fiduciari oltre a quelle esplicitamente trasmesse durante lo scrutinio.

Durante la fase di sblocco, l'unica informazione fornita dal Trustee è la propria share. La resistenza contro lo scenario *Malicious* nel gioco $\mathcal{G}_{\mathcal{A}_{FID}}^{tally}$ si fonda sui meccanismi di impegno crittografico stabiliti dall'entità $\mathcal{E}$ nella fase di setup e registrati sul bollettino pubblico. Qualsiasi tentativo da parte di un fiduciario di trasmettere una share falsa viene smascherato deterministicamente durante la ricomputazione pubblica: il sistema verifica la corrispondenza del dato fornito con l'impegno iniziale, neutralizzando immediatamente la minaccia e impedendo alterazioni del risultato.

1.3.3 Analisi degli Scenari di Minaccia

A valle della classificazione formale degli avversari, in questa sezione si declinano i *threat models* all'interno degli specifici scenari operativi del sistema Aequitas. L'obiettivo è mappare le capacità offensive degli attaccanti rispetto alle fondamentali proprietà di sicurezza elettorale che il protocollo intende preservare: autenticità, unicità, segretezza, integrità, verificabilità individuale e universale.

1.3.3.1 Autenticità e unicità dell'espressione di voto

In sede elettorale, l'accesso al sistema di voto è strettamente vincolato alla verifica dell'eleggibilità. La fase di autenticazione e accreditamento, demandata all'entità IAP, è soggetta a specifiche minacce dirette all'alterazione del corpo elettorale.

Un primo scenario critico prevede che l'IAP agisca come attore malevolo ($\mathcal{A}_{IAP}$), compromettendo l'**integrità dell'eleggibilità** mediante l'ammissione al voto di utenti sprovvisti di diritto (es. generazione di autorizzazioni fittizie). Il sistema deve prevenire che una corruzione dell'IAP si traduca nell'accettazione di voti invalidi a valle. Parallelamente, un votante malizioso ($\mathcal{A}_V$) potrebbe tentare l'apertura di molteplici sessioni parallele per aggirare i controlli di stato, al fine di esprimere più voti con una singola identità. Il protocollo deve dunque garantire l'**unicità in fase di emissione e di esercizio**, prevenendo la multi-autorizzazione e risolvendo eventuali situazioni di concorrenza in cui richieste discordanti vengano sottomesse in rapida successione al nodo VBR.

A livello di rete, un attaccante esterno ($\mathcal{A}_{ext}$) potrebbe tentare attacchi di *Man-in-the-Middle*. Pertanto, il sistema è tenuto a dimostrare l'**Autenticità dell'Infrastruttura** per impedire che l'elettore interagisca con componenti contraffatti. Risulta inoltre imperativo che il sistema permetta di esibire una **Prova di Eleggibilità** verificabile autonomamente da chi riceve il voto, ma del tutto disaccoppiata dall'identità reale del votante — nei limiti delle assunzioni di fiducia dichiarate nella sezione 1.4.1.

1.3.3.2 Segretezza, unlinkability e resistenza alla coercizione

La segretezza del voto è il pilastro per mitigare i rischi di coercizione e condizionamento psicologico. Il threat model prevede che un avversario interno (come $\mathcal{A}_{IAP}$ o $\mathcal{A}_{VBR}$), o la loro collusione, tenti di risalire all'identità del votante a partire dalla preferenza registrata nel VBR. A questo proposito è fondamentale distinguere due livelli di protezione distinti che il sistema intende fornire.

Il primo riguarda la **segretezza del contenuto del voto**: il voto deve rimanere inaccessibile a qualsiasi entità durante tutta la fase di raccolta, e deve poter essere rivelato solo al termine della votazione, in fase di scrutinio, nelle condizioni e con le garanzie previste dal protocollo. Questa proprietà deve essere garantita matematicamente, indipendentemente dal comportamento degli attori coinvolti.

Il secondo livello riguarda l'**unlinkability tra identità e voto**: nessuna singola entità deve essere in grado di associare l'identità autenticata del votante alla preferenza registrata. Questa proprietà, come discusso nella sezione 1.4.1, è garantita proceduralmente dall'assunzione di non collusione tra le entità preposte all'autenticazione e alla raccolta dei voti e rappresenta il principale rischio residuo dell'architettura.

Un ulteriore vettore di attacco all'unlinkability è rappresentato dai **metadati di comunicazione**: anche in assenza di collusione esplicita, un avversario che osservi i tempi e le sequenze delle interazioni tra il votante e le diverse entità del sistema potrebbe tentare correlazioni statistiche per de-anonimizzare i voti. Il sistema deve pertanto considerare misure atte a disaccoppiare temporalmente le diverse fasi del protocollo.

Infine, si palesa un **trade-off** progettuale consapevole **tra verificabilità individuale e resistenza assoluta alla coercizione**. Qualora il sistema rilasciasse un'evidenza per il controllo del proprio voto, un attore malevolo potrebbe esigerla per verificare il rispetto di direttive coercitive. In linea con le direttive del progetto, si è scelto di privilegiare la verificabilità individuale per promuovere la fiducia nel mezzo elettronico, accettando come rischio residuo la coercibilità post-voto, ritenendo quest'ultima una problematica socio-ambientale difficilmente arginabile dai soli costrutti crittografici.

1.3.3.3 Integrità della Scelta e del Computo

Le minacce legate alla manipolazione dei risultati rappresentano lo scenario di attacco a più alto impatto. I malintenzionati possono operare in diverse fasi del flusso elettorale:

- **integrità della scelta:** un attaccante di rete ($\mathcal{A}_{ext}$) può tentare di intercettare, alterare o effettuare un *replay attack* sul pacchetto di voto. Il sistema deve garantire l'autenticità del payload tramite un meccanismo di verifica basato su una **ricevuta di voto** poggiata su **Hash**. Ciascuno elettore può verificare la presenza della propria ricevuta nel registro pubblico e in fase di scrutinio può anche verificare l'integrità della scelta tramite l'utilizzo di un **pre-messaggio** pubblicato dai fiduciari.
- **Integrità della registrazione:** un nodo malizioso preposto alla raccolta ($\mathcal{A}_{VBR}$) potrebbe elaborare regolarmente il voto, per poi ometterlo silenziosamente o sostituirlo prima della persistenza. Parallelamente, un malfunzionamento o un attacco potrebbe interrompere il flusso dopo che il diritto di voto è stato consumato ma prima che il pacchetto venga registrato, impedendo all'elettore di votare nuovamente senza che il suo voto risulti nell'urna. Per arginare queste minacce, ogni voto accettato deve essere inserito in un registro immutabile e la sua avvenuta registrazione deve essere verificabile dall'elettore.
- **Integrità del computo:** in fase di scrutinio, i fiduciari potrebbero tentare di alterare il risultato finale rivelando porzioni di segreto deliberatamente scorrette o falsificate. Poiché le operazioni di decifratura sono interamente pubbliche e basate sui dati consolidati nel registro VBR, il risultato finale deve poter essere ricalcolato e validato in autonomia da chiunque. L'integrità dello spoglio non dipende quindi dall'onestà comportamentale dei trustee, ma dalla verifica crittografica delle loro share contro gli impegni stabiliti inizialmente. Di conseguenza, il corretto svolgimento del computo poggia esclusivamente sull'assunzione di onestà dell'autorità elettorale nella corretta generazione e pubblicazione di tali impegni.

1.3.3.4 Verificabilità Individuale e Universale

Affinché le operazioni sopra descritte siano verificabili, il sistema deve resistere ad attacchi mirati a comprometterne la trasparenza.

Sul fronte della **verificabilità individuale**, la minaccia principale è rappresentata da un attacco all'endpoint del client: un malware locale o una manipolazione del canale di rete potrebbe restituire all'elettore una falsa conferma di corretta registrazione del voto, ingannandolo sulla reale inclusione della propria preferenza nell'urna. Le prove di inclusione fornite dal registro devono pertanto essere verificabili matematicamente e autonomamente dal client tramite la ricevuta di verifica personale, senza doversi fidare di alcuna entità intermedia.

Sul fronte della **verificabilità universale**, si delinea il rischio che un'infrastruttura malevola alteri il registro o il risultato finale senza che la manipolazione sia rilevabile. Il registro

deve pertanto fondarsi su strutture dati crittograficamente verificabili, la cui impronta sia congelata e firmata dall'autorità elettorale al momento della chiusura delle urne. Chiunque può verificare che il numero di pacchetti nel VBR corrisponda al risultato pubblicato e che ogni pacchetto sia corredato di una firma valida dell'IAP. La correttezza del computo finale è garantita dalla natura pubblica della cerimonia di scrutinio, durante la quale ogni osservatore può ricalcolare il risultato e validare le share dei fiduciari, traslando la necessaria assunzione di onestà unicamente verso l'entità responsabile del setup iniziale. Infine, va considerata con estrema attenzione la **minaccia di de-anonimizzazione in fase di spoglio**. Poiché il protocollo prevede la decifratura e lo scrutinio in chiaro di *tutte* le singole schede in maniera pubblica, il rischio che un attaccante sfrutti i metadati temporali o l'ordine di registrazione nel VBR per correlare i voti alle identità dei votanti rappresenta una criticità di primario livello. È pertanto imperativo e fondamentale che l'architettura implementi misure rigorose per rimescolare e disaccoppiare in modo irreversibile l'ordine di ricezione dei pacchetti prima della loro decifratura, garantendo che la sequenza con cui i voti in chiaro vengono rivelati non possa in alcun modo tradire l'identità dell'elettore.

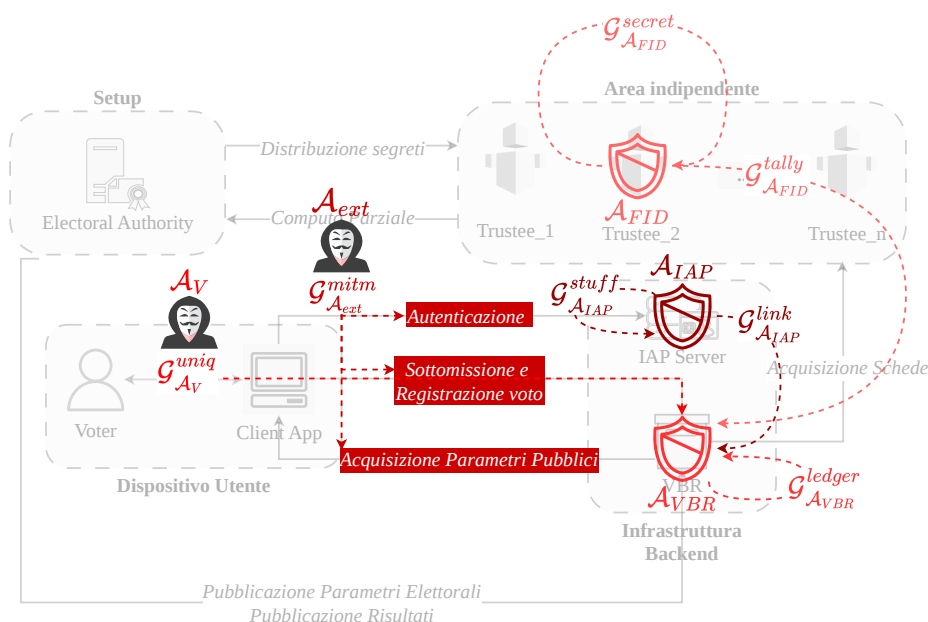


Figura 1.2: Diagramma dei Threat Models e Scenari di Attacco

1.4 Vincoli progettuali e trade-offs

1.4.1 Assunzioni di fiducia e rischio residuo

Alla luce delle vulnerabilità mostrate nel paragrafo 1.3.2, in questa sezione si definiscono le **assunzioni di fiducia** e i **rischi residui** del sistema. Questo paragrafo è di fondamentale importanza per illustrare i limiti intrinseci del sistema e dimostrare come, pur in presenza di costrutti crittografici solidi, la sicurezza globale dipenda da precise precondizioni operative.

- **Assunzione di fiducia sull'Electoral Authority $\mathcal{E}$** : si assume che l'autorità elettorale $\mathcal{E}$ sia un'entità *fully trusted* durante la fase di *setup* iniziale. Ad essa è demandata la generazione delle chiavi, la distribuzione delle share ai fiduciari e la pubblicazione degli impegni crittografici esatti sul bollettino pubblico. A valle di queste operazioni, la chiave segreta dell'elezione sk_{election} viene eliminata in modo sicuro. Questa eliminazione non contraddice la fiducia iniziale, ma è una misura architetturale ben precisa: trasferendo il possesso del segreto esclusivamente in forma distribuita ai Trustee, si elimina il *single point of failure* e si garantisce che nemmeno l'autorità stessa possa decifrare i voti in anticipo durante la fase di raccolta.
- **Assunzione di fiducia su un subset di Trustees $\mathcal{T}$** : l'insieme degli n fiduciari $\mathcal{T}$ è modellato sotto l'assunzione **Honest-but-Curious** esclusivamente per quanto riguarda la **privacy durante la votazione**: si assume che le entità non colludano per raggiungere la soglia t al fine di estrarre il segreto a urne aperte (prevenendo il gioco $\mathcal{G}_{\mathcal{A}_{FID}}^{\text{secret}}$). Per quanto concerne invece la correttezza dello scrutinio, i fiduciari non operano sotto un'assunzione di fiducia comportamentale, bensì come attori **responsabili e verificabili**: qualsiasi deviazione dal protocollo viene rilevata deterministicamente in fase di ricomputazione pubblica. La sicurezza contro il gioco $\mathcal{G}_{\mathcal{A}_{FID}}^{\text{tally}}$ non poggia dunque sull'onestà comportamentale dei fiduciari, ma sulla verifica crittografica delle share contro gli impegni pubblicati da $\mathcal{E}$ al setup. Permane tuttavia un **rischio residuo** in merito alla segretezza: poiché la verificabilità universale richiede che l'esito dello scrutinio sia pubblicamente ricalcolabile, il contenuto in chiaro di tutte le schede diventa accessibile a chiunque al termine della votazione. La protezione del voto si appoggia quindi interamente sulla **pseudonimia** (il disaccoppiamento tra identità e scheda), rendendo critica la non-collusione tra i nodi.
- **Assunzione di fiducia sull'entità IAP**: la soluzione architetturale proposta da Aequitas definisce l'IAP come un attore *fully trusted* per quanto riguarda la privacy. La responsabilità sulla gestione del ciclo di vita dei dati elaborati durante l'accreditamento, inclusa la loro eventuale ritenzione o cancellazione a valle dell'emissione della firma, è demandata esclusivamente alle *policy* dell'ente gestore dell'infrastruttura.
Questa assunzione risulta fondamentale per prevenire il gioco di *ballot stuffing* ($\mathcal{G}_{\mathcal{A}_{IAP}}^{\text{stuff}}$): se l'IAP operasse in modo malevolo, potrebbe generare falsi certificati e autorizzare al voto entità inesistenti; il VBR non avrebbe alcuno strumento matematico per rigettarli, in quanto le firme risulterebbero crittograficamente valide. Dunque, risulta necessario assumere l'IAP come entità istituzionale fidata a livello organizzativo. La mitigazione di questo **rischio residuo** è demandata a procedure extra-protocollo come il confronto a fine elezione tra il numero di schede nel VBR e il numero di elettori fisicamente registrati.

- **Non-collusione tra IAP e VBR:** lo pseudo-anonimato del votante e la prevenzione del gioco di *Linkability* ($\mathcal{G}_{\mathcal{A}_{IAP}}^{link}$) si fondano sull'assunzione che l'IAP e il VBR operino in domini di sicurezza strettamente separati. Qualora queste due entità colludessero scambiandosi i metadati come log di traffico, indirizzi IP o timestamp, potrebbero incrociare l'identità anagrafica dell'elettore con il pacchetto di voto sot-tomesso. La collusione diventa ancora più critica *dopo* lo spoglio, perchè per la progettazione di Aequitas, la relazione $R \leftrightarrow v$ è pubblica e la de-anonimizzazione non richiede nemmeno accesso ai log del VBR: è sufficiente che l'IAP osservi il registro pubblico. Questo rischio residuo è una conseguenza delle primitive critto-grafiche adottate: una soluzione effettiva a questo problema richiederebbe primitive aggiuntive esterne al perimetro del presente lavoro.
- **Fiducia limitata alla Disponibilità per il VBR:** a differenza dell'IAP, il VBR è disegnato con un approccio *trustless* per quanto riguarda l'integrità e la segretezza dei dati. Il gioco di alterazione del registro ($\mathcal{G}_{\mathcal{A}_{VBR}}^{ledger}$) viene neutralizzato attivamente dai meccanismi crittografici di verificabilità individuale e universale. Tuttavia, per-mane un'assunzione di fiducia operativa legata alla **disponibilità**: se il VBR agisse in modo malevolo attuando un'interruzione di servizio, il processo elettorale verrebbe interrotto. Questa vulnerabilità, tuttavia, esula dalle garanzie crittografiche del protocollo Aequitas.
- **Onestà degli End-point:** si assume che il dispositivo personale dell'elettore non sia compromesso da malware o software spia capaci di sottrarre i parametri di voto o manipolare l'interfaccia utente all'insaputa del cittadino. La messa in sicurezza del dispositivo ospite esula dal perimetro di protezione tecnologica del protocollo Aequitas.
- **Autenticità dei parametri elettorali e radice di fiducia:** per neutralizzare gli attacchi mirati alla sostituzione dei parametri elettorali (in particolare la chiave pubblica dell'elezione pk_{elec}) da parte dell'attaccante esterno ($\mathcal{A}_{ext}$), Aequitas non si appoggia ad assunzioni di fiducia su infrastrutture esterne, bensì a una garanzia crittografica interna al protocollo: in fase di setup, l'Electoral Authority $\mathcal{E}$ firma pk_{elec} con la propria chiave istituzionale $sk_{\mathcal{E}}$ prima della sua distruzione, consentendo a qualunque client di verificarne l'autenticità tramite $pk_{\mathcal{E}}$. Un avversario non può quindi distribuire parametri contraffatti senza produrre una firma valida, operazione computazionalmente intrattabile. Permane tuttavia un'unica radice di fiducia non eliminabile crittograficamente: l'autenticità di $pk_{\mathcal{E}}$ stessa, la cui distribuzione deve avvenire tramite un canale fidato (ad esempio pubblicazione su registro istituzionale ufficiale). Questa assunzione è ineliminabile per costruzione, poiché ogni schema di certificazione richiede una chiave di fiducia stabilita al di fuori del protocollo stesso.
- **Onestà comportamentale del Votante:** oltre all'integrità del dispositivo, si assume che l'elettore stesso non riveli volontariamente o ceda a terzi i propri segreti o la propria ricevuta di verifica. Qualora il votante decidesse di cooperare attivamente con un coercitore fornendo tali prove per dimostrare la propria preferenza, decadrebbe il perimetro di protezione e nessuna proprietà formale di *unlinkability* potrebbe impedire la violazione del segreto elettorale. Si precisa che tale assunzione di fiducia riguarda **esclusivamente la sfera della privacy**: al contrario, il sistema non fa alcuna assunzione di onestà riguardo ai tentativi di frode tecnica (come il voto multiplo o la manipolazione delle sessioni), che vengono invece neutralizzati attivamente dai vincoli matematici dell'architettura.

1.4.2 Revocabilità e Sostituzione del Voto

Un ulteriore parametro progettuale critico riguarda la gestione della revocabilità del voto prima della chiusura delle urne. Per il sistema Aequitas, si è scelto di **non consentire** la sostituzione del voto una volta che questo è stato persistito nel VBR.

Sebbene permettere il ri-voto (considerando valido solo l'ultimo sottomesso) offra una forte mitigazione contro la coercizione istantanea (l'elettore può votare sotto minaccia e poi cambiare il voto in privato successivamente), tale approccio introduce enormi criticità su **integrità e unicità**. Consentire l'aggiornamento del voto in un registro *append-only* pubblico richiede complessi meccanismi crittografici di revoca che aumenterebbero drasticamente il carico computazionale. Avendo prioritizzato la **verificabilità universale e la semplicità di scrutinio**, si è optato per il compromesso di un voto unico e inalterabile, delegando la protezione dalla coercizione alla segretezza *end-to-end* e all'isolamento al momento del voto.

1.4.3 Vincoli di Efficienza e Scalabilità

Considerando lo scenario applicativo delle elezioni comunali con preferenza nominale, il sistema è chiamato a servire un corpo elettorale su larga scala gestendo schede elettorali con *payload* crittografici potenzialmente complessi. Questo impone tre vincoli operativi fondamentali che guideranno la scelta delle primitive in WP2:

- **Costo computazionale lato client:** Le operazioni crittografiche delegate all'applicazione dell'elettore devono essere eseguite in tempi impercettibili per l'utente, garantendo la piena accessibilità del servizio anche su dispositivi mobili.
- **Overhead di rete:** La dimensione dei pacchetti crittografici scambiati tra Votante, IAP e VBR deve essere rigorosamente minimizzata per permettere l'esercizio del voto anche in condizioni di connettività non ottimali.
- **Scalabilità e throughput del server (VBR):** Il server di ricezione deve essere progettato per sostenere elevati picchi di traffico concorrente (tipici delle prime e delle ultime ore di apertura delle urne). Pertanto, i controlli di validità crittografica in fase di ammissione del pacchetto devono essere asintoticamente leggeri, delegando eventuali computazioni più onerose alla successiva fase di scrutinio a urne chiuse.